

Regra de Negócio: Usuários

docs/business-rules

Ciclartech · Plataforma de Gestão de Ativos Assistivos

Usuários

Objetivo

Definir corretamente a hierarquia de usuários (Owner → Admin → Gestor → Funcionário) e garantir que cada nível só gerencie quem está abaixo dele, dentro do próprio tenant.

Fluxo operacional

Owner cadastra o cliente (tenant) e o(s) Administrador(es)

↓

Administrador cadastra Gestores e Funcionários, atribuindo papel e unidades permitidas

↓

Cada usuário opera dentro do que seu papel permite

Regras de negócio

- Papel (`Papel`) define `codigo` (`admin` , `gestor` , `funcionario`) e `nivel_hierarquico` (Admin=30, Gestor=20, Funcionário=10) — único por papel, usado em toda checagem de permissão do sistema.
- Owner (`is_platform_staff=True`) nunca pertence a um tenant — reforçado por `CheckConstraint` no banco (`owner_nao_pertence_a_tenant`).
- Usuário de cliente (não Owner) precisa obrigatoriamente ter `tenant_id` preenchido (`Usuario.clean()`).
- `pode_gerenciar(outro_usuario)` : Owner gerencia qualquer usuário; um usuário de cliente só gerencia usuários do **mesmo tenant** cujo nível hierárquico seja menor ou igual ao seu papel — ou seja, Admin gerencia Gestor e Funcionário, Gestor não gerencia Admin.
- Todo usuário de cliente pode ter unidades atribuídas (`Usuario.unidades`) — ver `docs/business-rules/unidades.md` para o detalhamento da regra de permissão de acesso.

Validações

- `tenant` obrigatório para não-Owner; proibido para Owner.
- Criação de usuário restrita ao papel de quem cria: só é possível atribuir um papel com `nivel_hierarquico` estritamente menor do que o do criador (um Gestor não consegue criar outro Gestor nem um Admin).

Permissões por perfil

Ação	Nível mínimo
Cadastrar/listar/ativar-desativar usuário	Gestor (respeitando <code>pode_gerenciar</code>)
Consultar auditoria do próprio tenant	Gestor ou Admin
Acessar área <code>/owner/*</code> (cross-tenant)	Somente <code>is_platform_staff</code>
Acessar área <code>/app/*</code> (operacional)	Qualquer usuário com <code>tenant_id</code> , não staff

Estados possíveis

Usuário `Ativo` / `Inativo` (`is_active`).

Transições permitidas

`Ativo ↔ Inativo`, alternável por quem tem permissão de gerenciar aquele usuário (`pode_gerenciar`).

Casos de exceção

- Um Gestor tentando cadastrar outro Gestor ou um Admin recebe erro de validação — o formulário nem oferece esses papéis como opção.
- Owner não aparece em nenhuma lista de usuários de tenant, mesmo tendo acesso irrestrito — ele vive fora do escopo de tenant por definição.

Impactos em outros módulos

- Define quem confirma cada checklist de empréstimo/devolução (rastreado por `Movimentacao.usuario`).
- Toda criação/alteração/desativação de usuário é capturada pela auditoria automática (`docs/business-rules/auditoria.md`).
- Unidades atribuídas ao usuário determinam o escopo de dados que ele deveria enxergar — ver pendências em `docs/business-rules/unidades.md`.